

SIMATS ENGINEERING

ASSESSMENT TOOL I – SCENARIO-BASED ASSESSMENT (HIGH)

Course Name: Ethical Hacking for Secure Networks	Code: ITA1436	CO: CO2
Duration: 90 min	Date:	Total Marks:
Reg. No: 192521366	Name: FRANKLIN A	

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks. (BL3)

Assessment Tool Weightage: 35%

Instructions: Answer all questions. Each question carries 10 marks.

Scenario 1: Passive Reconnaissance using WHOIS and Recon-ng

A cybersecurity analyst collects publicly available information about a target organization using WHOIS, Recon-ng, and search engines before performing active scanning.

Q1. Explain how WHOIS can be used during footprinting.

WHOIS is a query/response protocol used to look up information stored in the registration databases of domain names and IP address blocks. During footprinting, an attacker or analyst queries WHOIS to gather information without directly interacting with the target's live systems, making it a passive reconnaissance technique.

- **Domain registration details:** registrant name, organization, registrar, creation/expiry dates
- **Administrative & technical contacts:** names, email addresses, and phone numbers of people managing the domain
- **Name servers:** which reveal the DNS infrastructure and possibly the hosting provider
- **IP address / netblock information:** via ARIN, RIPE, APNIC, etc., to identify address ranges owned by the organization

This information helps build a profile of the organization, identify potential social engineering targets (contact emails), and map out the network ownership before active scanning begins.

Q2. What information can Recon-ng gather about a target organization?

Recon-ng is a full-featured, web-based reconnaissance framework written in Python that automates OSINT (Open Source Intelligence) gathering through modular recon modules.

- **Domain and subdomain enumeration:** discovering related subdomains and hosts
- **Contact and employee information:** harvesting email addresses and personnel names from public sources
- **IP addresses and geolocation:** resolving hosts to IPs and mapping their locations
- **Social media and public profiles:** linking company presence across platforms
- **Vulnerability and port data:** when integrated with APIs such as Shodan or Censys

It stores all findings in a workspace database, allowing the analyst to correlate data across modules and generate a consolidated footprinting report.

Q3. Why is passive information gathering preferred before active scanning?

- **Stealth:** passive methods (WHOIS, search engines, public records) do not send packets to the target, so they leave no trace and cannot trigger intrusion detection/prevention systems

- **Legal safety:** collecting publicly available data avoids unauthorized access issues that active scanning could raise
- **Risk reduction:** it avoids alerting the target organization's security team before the assessment is authorized to proceed further
- **Better planning:** the information gathered passively helps scope and prioritize which systems to actively scan, making the active phase faster and more targeted

Overall, passive reconnaissance builds a low-risk foundation of knowledge that makes subsequent active scanning more efficient and less detectable.

Scenario 2: Competitive Intelligence using BuiltWith and SimilarWeb

A security consultant analyzes competitor websites using BuiltWith and SimilarWeb to understand technologies, hosting platforms, and traffic patterns for business and security strategy.

Q1. How does BuiltWith help in competitive intelligence?

BuiltWith is a website profiler tool that scans a site and reports the technology stack it uses.

- **Technology stack:** identifies CMS, frameworks, JavaScript libraries, and server-side technologies in use
- **Hosting and infrastructure:** reveals hosting provider, CDN, and DNS provider
- **Third-party services:** detects analytics tools, advertising networks, payment processors, and plugins
- **Historical technology changes:** shows how a competitor's tech stack has evolved over time

This helps a security team benchmark their own technology choices against competitors and also identify known vulnerabilities associated with specific software versions or plugins in use.

Q2. What type of information can SimilarWeb provide?

- **Traffic volume and trends:** estimated monthly visits and growth/decline patterns
- **Traffic sources:** breakdown by direct, search, social, referral, and paid channels
- **Audience demographics:** geography, age, and interest categories of visitors
- **Engagement metrics:** average visit duration, pages per visit, and bounce rate
- **Competitor and industry benchmarking:** ranking against similar websites in the same market

This data helps an organization understand a competitor's market reach and popularity, indirectly indicating which platforms may be higher-value targets for attackers due to larger user bases.

Q3. How can competitive intelligence improve cybersecurity planning?

- **Attack surface awareness:** knowing which technologies are industry-standard helps predict what attackers might target
- **Benchmarking security posture:** comparing security practices, certificates, and technologies against competitors highlights gaps
- **Vendor risk assessment:** identifying shared third-party tools/services that could introduce common vulnerabilities
- **Informed resource allocation:** traffic and reach data helps prioritize protection for high-traffic, high-value digital assets

In short, competitive intelligence translates market and technology insights into concrete, prioritized security investments.

Scenario 3: DNS Enumeration on Public-Facing Infrastructure

An ethical hacker performs DNS enumeration and discovers undocumented subdomains and mail server configurations for a financial organization.

Q1. What is DNS enumeration?

DNS enumeration is the process of querying an organization's Domain Name System (DNS) servers to discover all associated DNS records, subdomains, and related hosts. It is a key part of the footprinting phase and helps an attacker or ethical hacker map out the target's network topology, including servers that may not be publicly advertised elsewhere.

Q2. Which DNS records are commonly collected during reconnaissance?

- **A / AAAA:** maps hostnames to IPv4/IPv6 addresses
- **MX:** identifies mail servers handling the organization's email
- **NS:** lists authoritative name servers for the domain
- **CNAME:** reveals alias/subdomain mappings to canonical hostnames
- **TXT:** may expose SPF records, verification tokens, or configuration details
- **SOA:** provides zone administration details, including refresh/serial data
- **PTR:** used for reverse DNS lookups to map IPs back to hostnames

Q3. How can exposed DNS information create security risks?

- **Attack surface mapping:** revealed subdomains (e.g., dev, test, admin panels) may expose forgotten or unpatched systems
- **Mail server targeting:** MX record exposure allows attackers to target email infrastructure for phishing or spoofing
- **Infrastructure fingerprinting:** NS and A records help attackers identify hosting providers and potentially vulnerable shared infrastructure
- **Information leakage via TXT records:** misconfigured TXT records can expose internal service tokens or configuration hints

Collectively, this undocumented information gives attackers a roadmap of internal and external hosts that were never meant to be publicly known, increasing the likelihood of successful targeted attacks.

Scenario 4: Search Engine Footprinting

An ethical hacker uses advanced search engine operators to discover publicly accessible files containing employee directories and configuration documents.

Q1. What is search engine footprinting?

Search engine footprinting (also called Google Dorking/Google Hacking when applied to Google) is the technique of using search engines and their advanced query operators to find publicly indexed but often unintentionally exposed information about a target — such as documents, login portals, configuration files, or directory listings — without directly interacting with the target's servers.

Q2. How do search operators help locate sensitive information?

- **site::** restricts results to a specific domain, e.g. site:company.com
- **filetype: / ext::** finds specific file types such as filetype:pdf or filetype:xls that may contain sensitive data
- **intitle: / inurl::** locates pages with specific words in the title or URL, such as inurl:admin or intitle:"index of"
- **intext::** searches for specific keywords within the page content, e.g. intext:"confidential"

Combining these operators (e.g., site:company.com filetype:xlsx intext:"employee") allows an attacker to precisely locate leaked spreadsheets, configuration files, or directories that were never meant to be public but got crawled and indexed by search engines.

Q3. What steps should organizations take to protect confidential files?

- **Use robots.txt and meta noindex:** to prevent search engines from crawling sensitive directories and files
- **Apply proper access controls:** authentication and authorization on all internal documents and portals
- **Regularly audit search engine exposure:** periodically Google-dork one's own domain to catch unintentionally indexed files
- **Secure cloud storage and file shares:** avoid public/unauthenticated links for internal documents
- **Employee awareness training:** educate staff on the risks of uploading sensitive files to publicly accessible locations

Combining technical controls with continuous monitoring significantly reduces the chance of confidential files being discoverable via search engines.

Scenario 5: DNS Zone Transfer Vulnerability

A DNS server is found to allow unrestricted zone transfers, exposing a complete list of internal and external hosts to unauthorized users.

Q1. What is a DNS zone transfer?

A DNS zone transfer (using the AXFR or IXFR mechanism) is the process by which a secondary/slave DNS server copies the complete DNS zone file from a primary/master DNS server, so both servers stay synchronized. The zone file contains every DNS record for the domain, including all hosts, subdomains, and mail servers.

Q2. Why is unrestricted zone transfer considered a security risk?

- **Complete network disclosure:** if any client can request a zone transfer, an attacker obtains the entire list of hostnames, subdomains, and IP addresses in a single query
- **Reveals internal architecture:** including systems never meant to be publicly known, such as internal servers, test environments, or backup hosts
- **Accelerates reconnaissance:** what would normally take extensive subdomain brute-forcing is obtained instantly and completely
- **Enables targeted attacks:** attackers can prioritize high-value hosts (e.g., mail servers, admin panels) revealed in the transfer

This turns a routine DNS administration feature into a major information-disclosure vulnerability when not properly restricted.

Q3. How can organizations prevent unauthorized zone transfers?

- **Restrict zone transfers:** configure the DNS server (e.g., BIND's allow-transfer, or equivalent in Windows DNS) to permit AXFR/IXFR only to specific, trusted secondary server IP addresses
- **Use TSIG authentication:** enable Transaction Signatures to cryptographically authenticate zone transfer requests between primary and secondary servers
- **Disable zone transfers where unnecessary:** if there are no secondary servers requiring transfers, disable the feature entirely
- **Monitor and log DNS queries:** detect and alert on unusual or unauthorized AXFR/IXFR requests
- **Regular security audits:** periodically test the DNS server (e.g., using dig axfr) from an external, unauthorized host to confirm transfers are blocked

Together, these measures ensure that only legitimate secondary name servers can replicate the zone data, closing off this common footprinting vector.

— End of Assessment —